

Splunk Boss v1 (Web Defacement)

Scenario 1

Web site defacement

Today is Alice's first day at the Wayne Enterprises' Security Operations Center. Lucius sits Alice down and gives her first assignment: A memo from Gotham City Police Department (GCPD). Apparently GCPD has found evidence online (<http://pastebin.com/Gw6dWjS9>) that the website www.imreallynotbatman.com hosted on Wayne Enterprises' IP address space has been compromised. The group has multiple objectives... but a key aspect of their modus operandi is to deface websites in order to embarrass their victim. Lucius has asked Alice to determine if www.imreallynotbatman.com. (the personal blog of Wayne Corporations CEO) was really compromised.

Incident Summary

Gotham City Police Department (GCPD) reported a potential compromise of www.imreallynotbatman.com, a personal blog hosted within **Wayne Enterprises'** IP address space.

The alert was triggered by content published online claiming responsibility for compromising and defacing the website. Website defacement is a known tactic used by the threat group to publicly embarrass high-profile organizations and individuals.

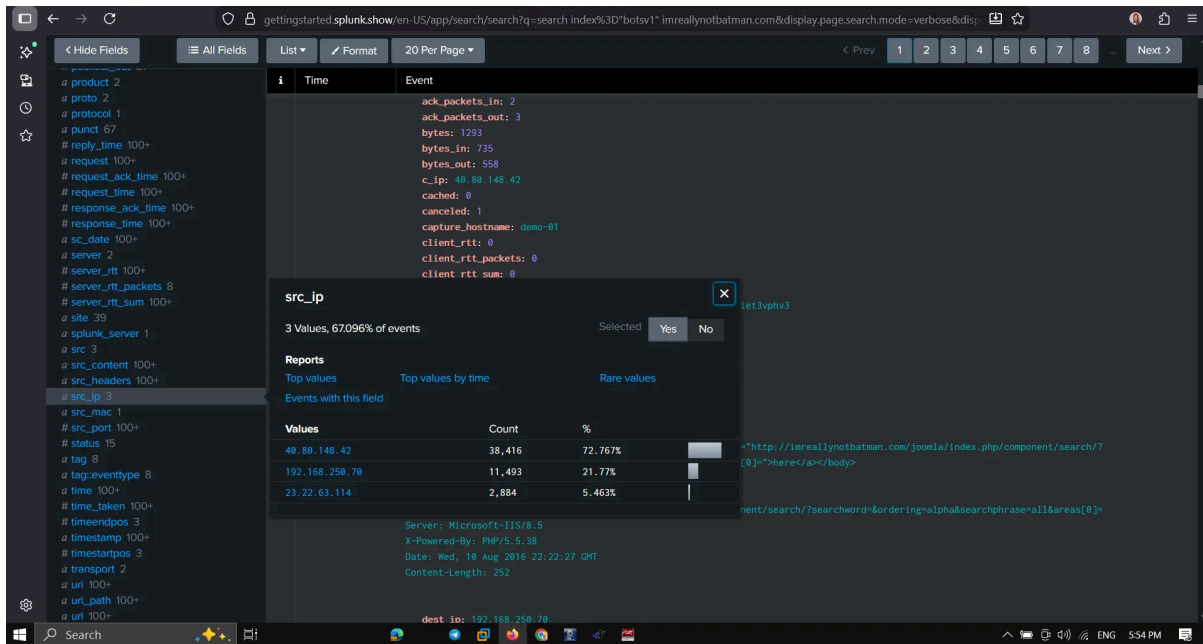
Scope Definition

- **Website:** www.imreallynotbatman.com
- **Organization:** Wayne Enterprises
- **Data Sources:** Web server logs, IDS/IPS alerts, external threat intelligence
- **External Evidence:** Pastebin post claiming responsibility for the compromise
- **Suspected Attack Type:** Web application compromise / website defacement
- **Time Range:** Based on the publication timestamp of the Pastebin post

#101

What is the likely IPv4 address of someone from the Po1sOn1vy group scanning imreallynotbatman.com for web application vulnerabilities?

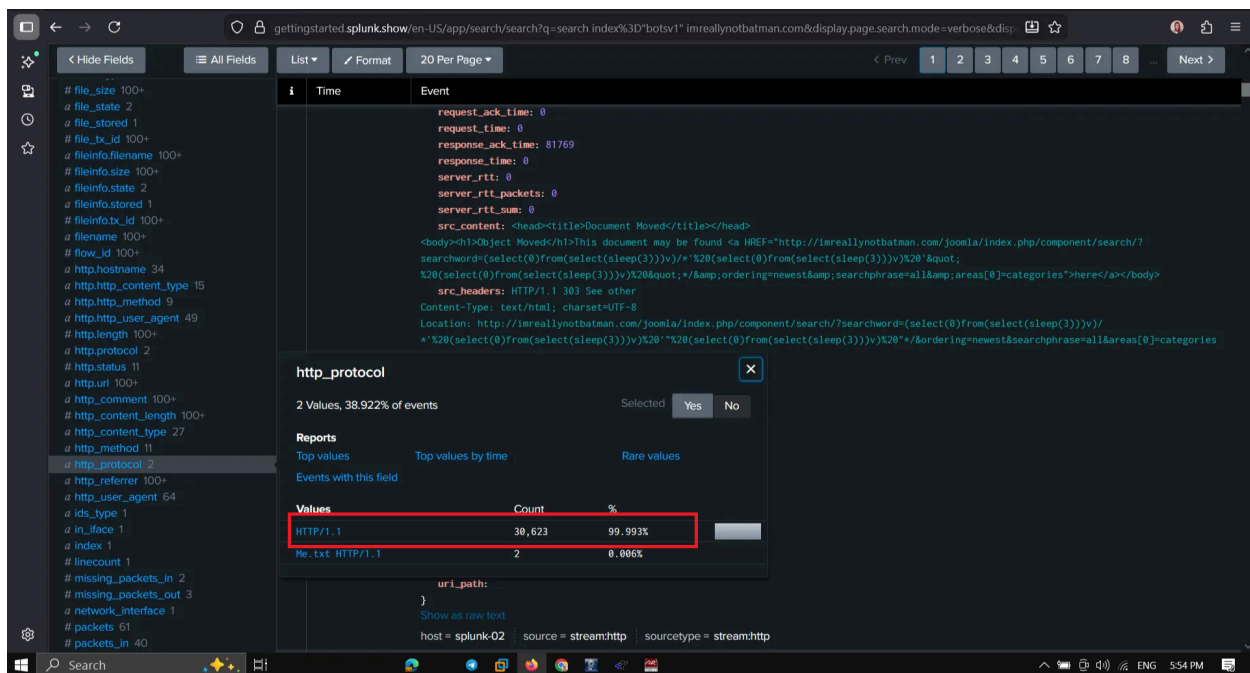
index="botsv1" imreallynotbatman.com



Search results for the query: `index="botsv1" imreallynotbatman.com`

Summary table for `src_ip`:

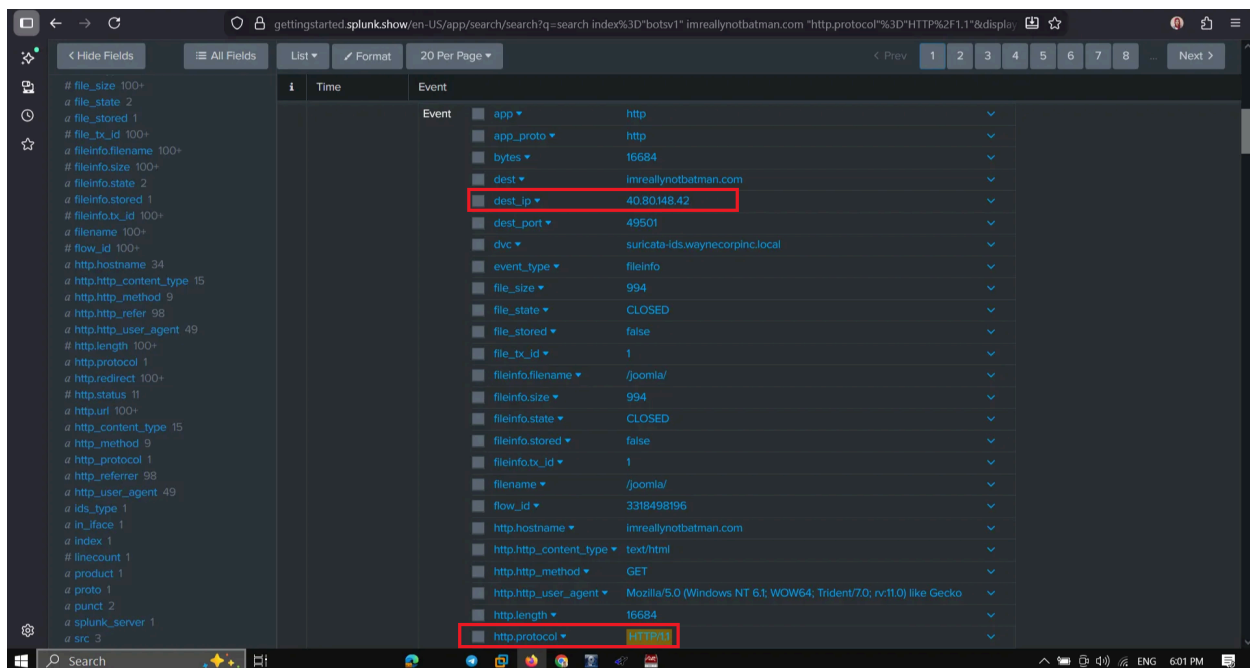
Values	Count	%
40.80.148.42	38,416	72.767%
192.168.250.70	11,493	21.77%
23.22.63.114	2,884	5.463%



Search results for the query: `index="botsv1" imreallynotbatman.com`

Summary table for `http.protocol`:

Values	Count	%
HTTP/1.1	30,623	99.993%
Me.txt HTTP/1.1	2	0.006%



Ans:40.80.148.42

1.note that i checked the is commonly used for web vulnerability scanning, because its commonly used for web vulnerability scanning.

2. 192.168.250.70 appears **suspicious**

#102

What company created the web vulnerability scanner used by Po1s0n1vy? Type the company name.

i checked the firewall logs to know the abnormal blocked actions.

gettingstarted.splunkshow/en-US/app/search/search?q=search index%3D%22botsv1%22 imreallynotbatman.com&display.page.search.mode=verbose&disj

splunk>enterprise Apps user001-splk Messages Settings Activity Help Find

Search Analytics Datasets Reports Alerts Dashboards

New Search

index="botsv1" imreallynotbatman.com All time

✓ 78,683 events (8/1/16 12:00:00.000 AM to 12/26/25 4:11:35.000 PM) No Event Sampling Job

Events (78,683) Patterns Statistics Visualization

Format Timeline Zoom Out Zoom to Selection Deselect 1 month per column

Hide Fields All Fields

SELECTED FIELDS

- a host 4
- a source 4
- a sourcetype 4

INTERESTING FIELDS

- # ack_packets_in 41
- # ack_packets_out 12
- a action 4
- a app 3
- a app_proto 1
- # bytes 100+
- # bytes_in 100+
- # bytes_out 100+
- a c_ip 3

sourcetype

4 Values, 100% of events

Selected Yes No

Reports

- Top values
- Top values by time
- Rare values
- Events with this field

Values	Count	%
suricata	38,625	38.922%
stream:http	22,200	28.214%
fgt_utm	13,918	17.689%
iis	11,948	15.175%

src_ip: 192.168.250.70
src_port: 80
timestamp: 2016-08-10T16:23:09.473182-0600

gettingstarted.splunkshow/en-US/app/search/search?q=search index%3D%22botsv1%22 imreallynotbatman.com sourcetype%3Dfgt_utm&display.page.sea

splunk>enterprise Apps user001-splk Messages Settings Activity Help Find

Search Analytics Datasets Reports Alerts Dashboards

New Search

index="botsv1" imreallynotbatman.com sourcetype=fgt_utm All time

✓ 13,918 events (8/1/16 12:00:00.000 AM to 12/26/25 4:13:25.000 PM) No Event Sampling Job

Events (13,918) Patterns Statistics Visualization

Format Timeline Zoom Out Zoom to Selection Deselect 1 month per column

Hide Fields All Fields

SELECTED FIELDS

- a host 1
- a source 1
- a sourcetype 1

INTERESTING FIELDS

- a action 3
- a attack 14
- # attackid 14
- # bytes 100+
- # bytes_in 100+
- # bytes_out 100+
- # cat 1
- a catdesc 1
- a category 1
- a clevel 4
- a cscore 4
- a date 1

action

3 Values, 100% of events

Selected Yes No

Reports

- Top values
- Top values by time
- Rare values
- Events with this field

Values	Count	%
allowed	19,026	136.701%
blocked	4,402	31.628%
deferred	1	0.007%

10:21:09.000 PM

eventtype=ftgd_allow level=notice vd="root" policyid=26 sessionid=933147 user="" srcip=40.80.148.42 srcport=49500 dstip=192.168.250.70 dstport=80 dstintf="internal3" proto=6 service=HTTP hostname="imreallynotbatman.com" profile="flow-monitor-all" action=passthrough reqtype=dire ct url="/joomla/administrator/index.php" sentbyte=580 rcvbyte=0 direction=N/A msg="URL belongs to an allowed category in policy" method=domain cat=0 catdesc="Unra

New Search

index="botsv1" imreallynotbatman.com sourcetype=fgt_utm action=blocked

4,402 events (8/16 12:00:00.000 AM to 8/16 12:00:00.000 AM)

attack

14 Values, 100% of events

Top 10 Values

Value	Count	%
Acunetix.Web.Vulnerability.Scanner	4,145	94.162%
HTTP.URI.SQL.Injection	199	4.521%
Bash.Function.Definitions.Remote.Code.Execution	18	0.409%
Apache.Camel.XSLT.Component.XXE	12	0.273%
PHP.CGI.Argument.Injection	10	0.227%
HTTP.XXE	6	0.136%
PhpMAdmin.moadmin.php.Unauthenticated.Remote.Code.Execution	3	0.068%
Apache.HTTP.Server.mod_rpaaf.X.Forwarded.For.DoS	2	0.045%
Oracle.GlassFish.Server.ThemeServlet.Directory.Traversal	2	0.045%
Apache.Roller.OGNL.Injection.Remote.Code.Execution	1	0.023%

Interesting Fields

- attack: 1
- attackid: 14
- crscore: 4
- date: 1
- date_hour: 1
- date_minute: 18

Event Details

```
vname=gotham-fortigate devid=FGT604614044725 logid=0419016384 type=utm subtype=1
p=40.80.148.42 srccountry="United States" dstip=192.168.250.70 dstintf="internal"
e=HTTP attack="Acunetix.Web.Vulnerability.Scanner" srcport=49488 dstport=80 hostn
profile="all_default_pass" ref="http://www.fortinet.com/ids/VID39769" incidentser
," crscore=5 crlevel=low
```

i googled the **tool name** that appeared also we can check the src header field for this one .

Google

Acunetix

Acunetix
https://www.acunetix.com

Acunetix | Web Application Security Scanner

Acunetix is an end-to-end web security scanner that offers a 360 view of an organization's security. Allowing you to take control of the security of all you ...

Website Vulnerability Scanning
Acunetix is the first web vulnerability scanner on the ...

Product
See how Acunetix makes it easier for your security team to ...

Acunetix Pricing and Packages
Your Acunetix subscription includes weekly Vulnerability ...

Get a demo
Acunetix is a web application security solution for scanning ...

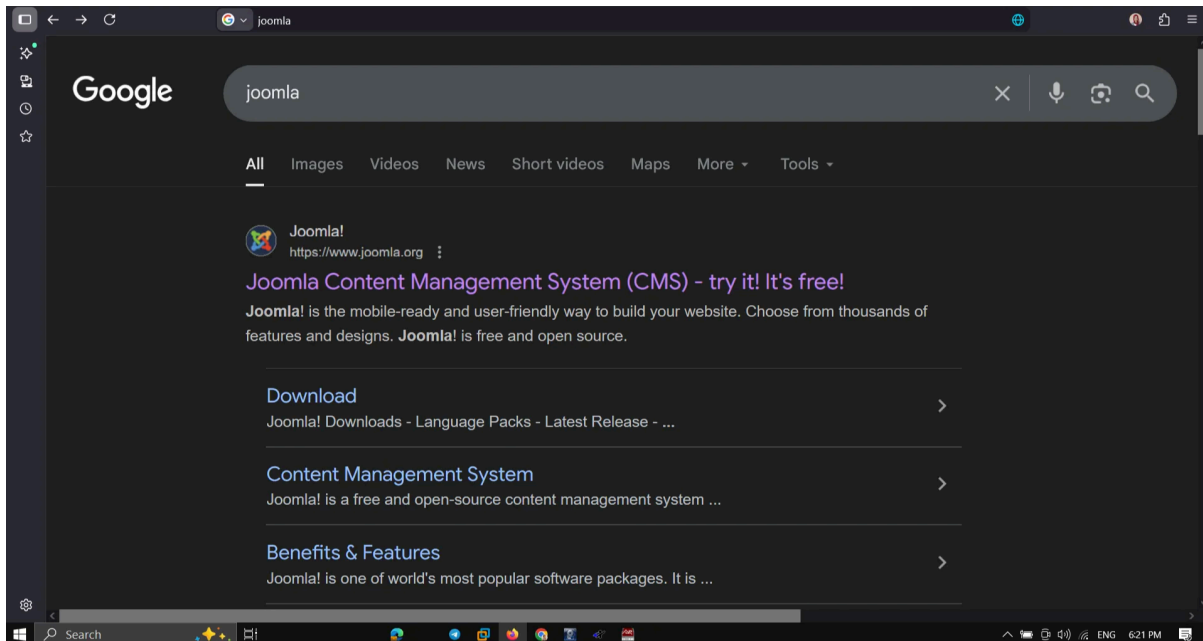
About Us
Acunetix by Invicti Security is an application security testing tool ...

More results from acunetix.com »

Ans:Acunetix

3. What content management system is imreallynotbatman.com likely using?
from #101

i checked url field to get content management system.

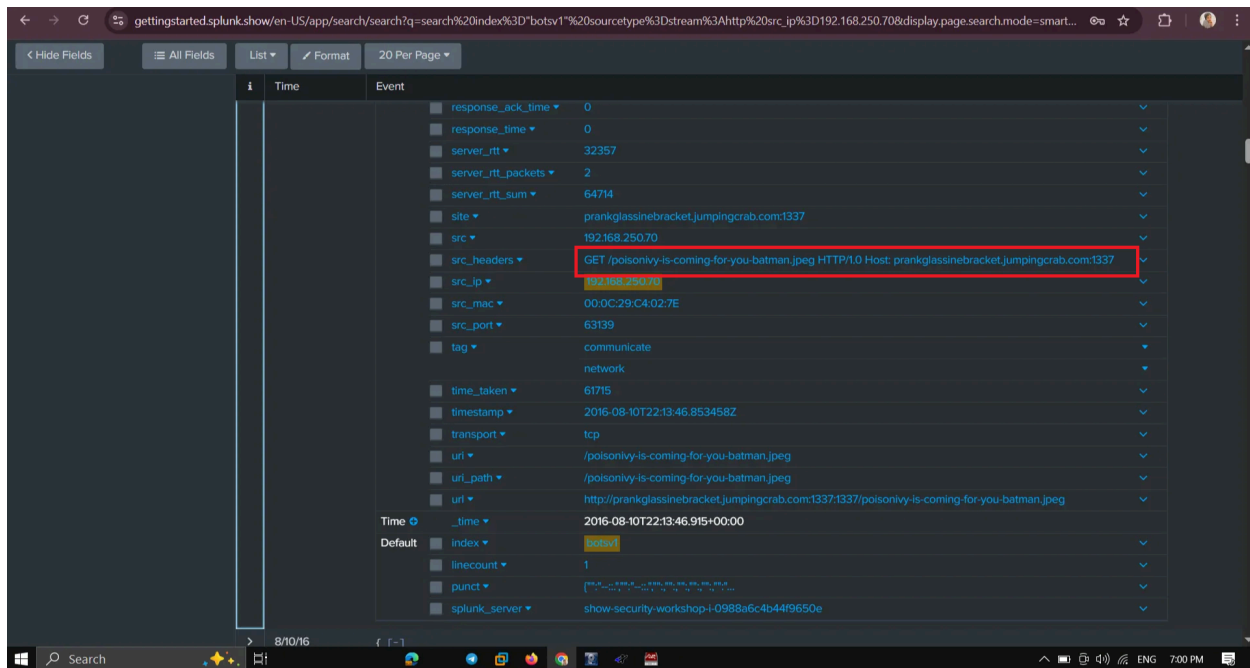


Ans:joomla

#104

What is the name of the file that defaced the imreallynotbatman.com website?
Please submit only the name of the file with extension?

```
index="botsv1" sourcetype=stream:http src_ip=192.168.250.70
```



Ans: poisonivy-is-coming-for-you-batman.jpeg

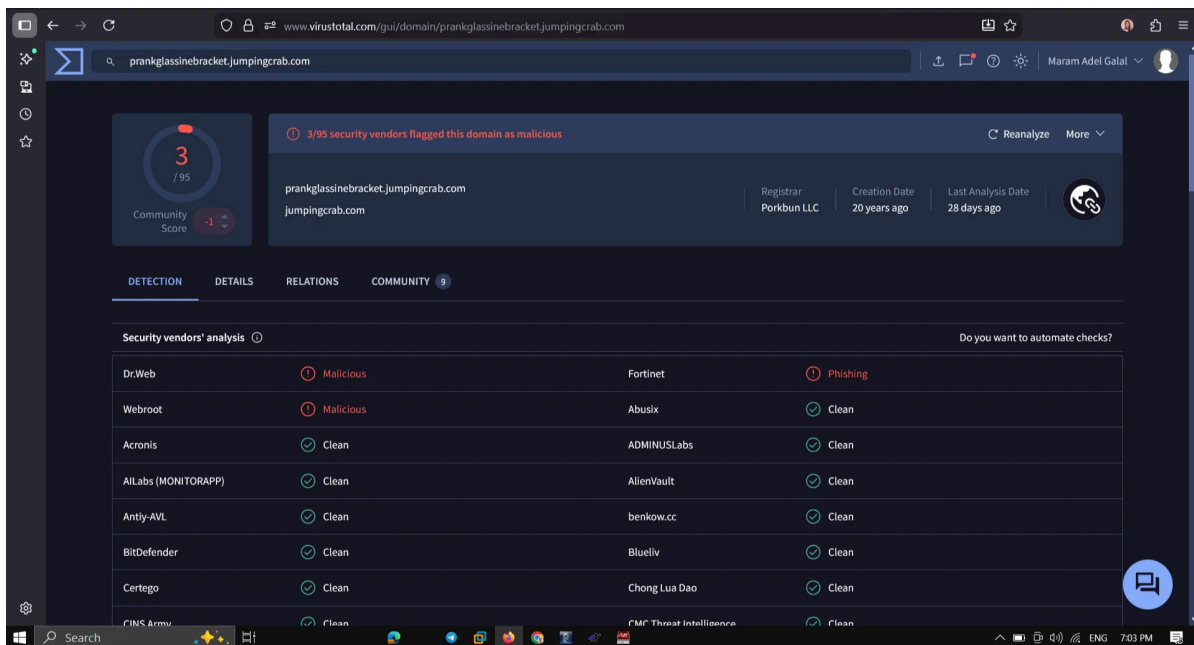
#105

This attack used dynamic DNS to resolve to the malicious IP. What fully qualified domain name (FQDN) is associated with this attack?

From #104

Ans: prankglassinebracketjumpingcrab.com

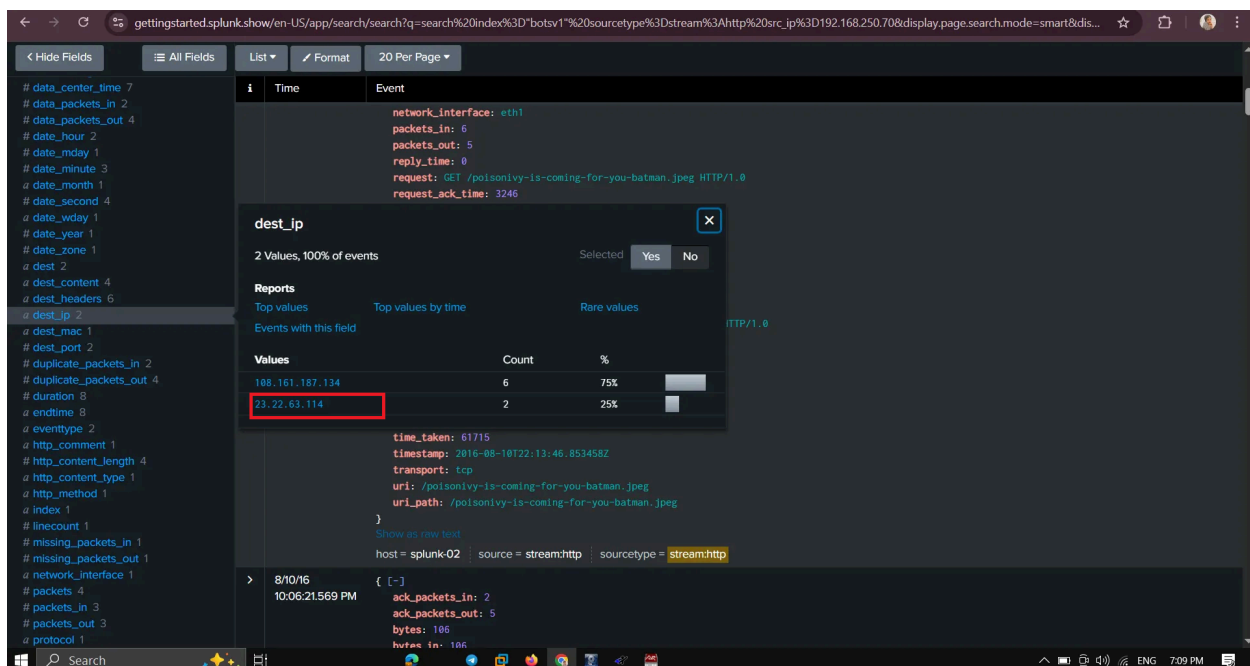
i also checked it on VT.



#106

What IPv4 address has Po1sOn1vy tied to domains that are pre-staged to attack Wayne Enterprises?

from the same query above #105



www.virustotal.com/gui/ip-address/23.22.63.114/relations

23.22.63.114

Maram Adel Galal

Communicating Files (5)

Scanned	Detections	Type	Name
2022-12-26	54 / 70	Win32 EXE	software.exe
2025-12-17	50 / 71	Win32 EXE	MirandaTateScreensaver.scr.exe
2025-01-27	70 / 72	Win32 EXE	IMDCSC.exe
2025-12-14	43 / 72	Win32 EXE	2025-12-01_34906dd70a8342ca4a67921a035f4812_elex_remc0s_rhadamanthys_stop
2025-12-25	64 / 72	Win32 EXE	ab.exe

Files Referring (27)

Scanned	Detections	Type	Name
2025-12-17	50 / 71	Win32 EXE	MirandaTateScreensaver.scr.exe
2025-12-14	43 / 72	Win32 EXE	2025-12-01_34906dd70a8342ca4a67921a035f4812_elex_remc0s_rhadamanthys_stop
2025-09-23	3 / 62	JSON	405abb807895c5d193737a50468ef9db93b49af1a5fe7117d38f70316aac2a76
2024-02-16	4 / 60	JavaScript	4a2acda88e3afa69ac4af60aeb25c30c3601a41974ee67df22594181fe961c7
2023-03-19	3 / 53	XML	d0bea02d993d4518f99782064611d89c.bin
2023-03-19	4 / 54	XML	c05d947f25d4ee2d230d0a4a73ed5ef6.bin
2023-03-17	4 / 59	XML	8a575d9efc2db6b5ec7acd3084aeb1c3.bin
2023-03-17	5 / 58	XML	adc27e30674270547cf960aefee83b.bin
2023-02-05	5 / 61	OpenOffice Document	940abd722b8d43bbf74445dcadb5c83d.a.1675612021271.xbkmap
2022-12-26	54 / 70	Win32 EXE	software.exe
2025-07-10	0 / 64	E-book	Data Analytics Using Splunk 9_x_ A Practical Guide to -- Dr. Nadine Shillingford -- 1, 2023 -- Packt Publishing, Limited; Packt Publishing -- 9781803245485 -- 0e99715e2bbba967a305e8ed0d273b3c -- Anna's Archive.epub
2025-02-24	0 / 64	Text	incident handling with Splunk.md
2024-09-12	0 / 64	MS Word Document	incident%20handling%20_1_((Autosaved-311308722505497888)).asd
2024-09-12	0 / 64	XML	document.xml.rels

Ans: 23.22.63.114

#108

What IPv4 address is likely attempting a brute force password attack against imrealllynotbatman.com?

I googled how to identify bruteforce attempt query on Splunk.

imrealllynotbatman.com passwd source="stream:http"

The screenshot shows the Splunk Boss v1 interface. The search bar contains the query: `search%20imreallynotbatman.com%20passwd%20source%3Dstream%3Ahttp&display.page.search.mode=smart&dispatch.sample...`. The left sidebar shows a list of fields, with `src_ip` selected. The main panel displays a table of events. A modal window titled `src_ip` is open, showing a table of values for the `src_ip` field. The table has three columns: Values, Count, and %. The first row, `23.22.63.114`, is highlighted with a red box and has a count of 1,235 and a percentage of 96.56%.

Values	Count	%
23.22.63.114	1,235	96.56%
48.88.148.42	44	3.44%

The screenshot shows the Splunk Boss v1 interface. The search bar contains the query: `search%20imreallynotbatman.com%20passwd%20source%3Dstream%3Ahttp&display.page.search.mode=smart&dispatch.sample...`. The left sidebar shows a list of fields, with `form_data` selected. The main panel displays a table of events. A modal window titled `form_data` is open, showing a table of values for the `form_data` field. The table has three columns: Values, Count, and %. The first row, `username=admin&0968493674eb04861bd64da9b662118=1`, is highlighted with a red box and has a count of 1 and a percentage of 0.243%.

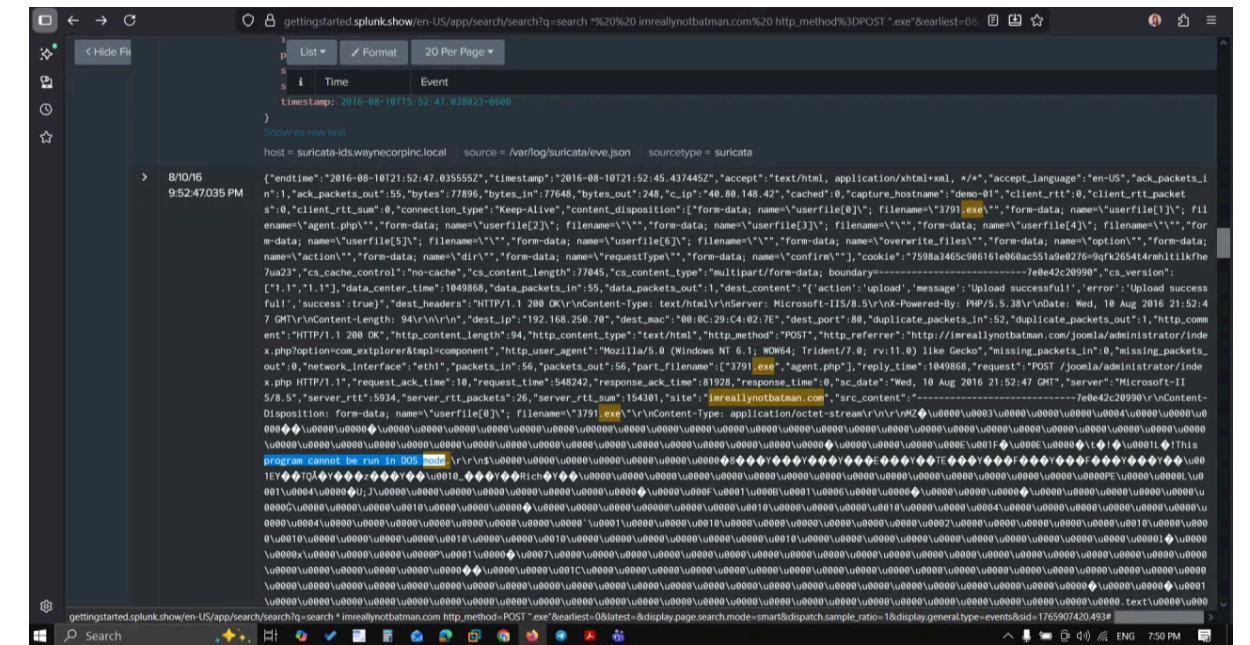
Values	Count	%
username=admin&0968493674eb04861bd64da9b662118=1	1	0.243%
username=admin&115c3aa6072f4b02b4354909431510f6=1	1	0.243%
username=admin&12c709bccc2e14d5a015f054d18d36537=1	1	0.243%
username=admin&2a2d9f7716c1d1e9da21cda782b231e=1	1	0.243%
username=admin&2c340c4e46444ba249ff7e599e6dfa52=1	1	0.243%
username=admin&32c15320bc3f78020869bb3bf17c28a6=1	1	0.243%
username=admin&593e38137076959941867bcdcc85562=1	1	0.243%

Ans:23.22.63.114

#109

What is the name of the executable uploaded by Po1s0n1vy?

* imreallynotbatman.com http_method=POST ".exe"



#110

What is the MD5 hash of the executable uploaded?

* "3791.exe" md5

Hashes

1 Value, 100% of events

Selected Yes No

Reports

Top values Top values by time Rare values

Events with this field

Values	Count	%
SHA1=65DF73D77324D008C83C3E57B445DF0D43A3A51, MD5=AAE3F5A29935E6ABCC2C2754D12A9AF0, SHA256=EC78C938D8453739CA2A370B9C275971EC46CAF6E479DE2B204E97CC47FA45D, IMPHASH=481F47BB82C9C21E108D65F52B04C448	1	100%

Ans:AAE3F5A29935E6ABCC2C2754D12A9AF0

#111

GCPD reported that common TTPs (Tactics, Techniques, Procedures) for the Po1s0n1vy APT group, if initial compromise fails, is to send a spear phishing email with custom malware attached to their intended target. This malware is usually connected to Po1s0n1vys initial attack infrastructure. Using research techniques, provide the SHA256 hash of this malware.

from #107

using VT

i checked MirandaTateScreensaver.scr.exe because

the .scr extension suggests it might be a **screensaver file**, which attackers often disguise as legitimate files to evade detection.

www.virustotal.com/gui/ip-address/23.22.63.114/relations

23.22.63.114

5 detected files communicating with this IP address

23.22.63.114 (23.20.0.0/14)
AS 14618 (AMAZON-AES)

US Last Analysis Date 12 hours ago

DETECTION DETAILS RELATIONS COMMUNITY 36

Passive DNS Replication (11)

Date resolved	Detections	Resolver	Domain
2019-12-01	0 / 95	VirusTotal	waynecorpinc.com
2019-11-30	0 / 95	VirusTotal	waneecorpinc.com
2019-11-29	0 / 95	VirusTotal	wyneecorpinc.com
2019-11-28	0 / 95	VirusTotal	waynecorpinc.com
2019-11-05	0 / 95	VirusTotal	waynecorpinc.com
2019-09-30	0 / 95	VirusTotal	waynecorpinc.com
2019-09-28	0 / 95	VirusTotal	waynecorpinc.com
2019-04-19	0 / 95	VirusTotal	ec2-23-22-63-114.compute-1.amazonaws.com
2018-07-18	0 / 95	VirusTotal	po1s0n1vy.com
2018-05-19	0 / 95	VirusTotal	www.po1s0n1vy.com
2018-05-02	3 / 95	VirusTotal	prankglassinebracketjumpingcrab.com

Communicating Files (5)

Scanned	Detections	Type	Name
2022-12-26	54 / 70	Win32 EXE	software.exe

Communicating Files (5)

Scanned	Detections	Type	Name
2022-12-26	54 / 70	Win32 EXE	software.exe
2025-12-17	50 / 71	Win32 EXE	MirandaTateScreensaver.scr.exe
2025-01-27	70 / 72	Win32 EXE	IMDCSC.exe
2025-12-14	43 / 72	Win32 EXE	2025-12-01_34906dd70a8342ca4a67921a035f4812_elex_remcos_rhadamanthys_stop
2025-12-25	64 / 72	Win32 EXE	ab.exe

www.virustotal.com/gui/file/9709473ab351387aab9e816eff3910b9f28a7a70202e250ed46dba8f820f34a8

9709473ab351387aab9e816eff3910b9f28a7a70202e250ed46dba8f820f34a8

50/71 security vendors flagged this file as malicious

9709473ab351387aab9e816eff3910b9f28a7a70202e250ed46dba8f820f34a8
MirandaTateScreensaver.scr.exe

Size 482.50 KB Last Analysis Date 9 days ago

peexe detect-debug-environment checks-user-input long-sleeps direct-cpu-clock-access

DETECTION DETAILS RELATIONS BEHAVIOR COMMUNITY 26+

Crowdsourced YARA rules

- Matches rule win_zupdax_auto from ruleset win_zupdax_auto at https://malpedia.caad.fkie.fraunhofer.de/ by Felix Bilstein - yara-signator at cocacoding dot com
Detects win_zupdax.
- Matches rule win_zupdax_auto from ruleset win_zupdax_auto at https://malpedia.caad.fkie.fraunhofer.de/ by Felix Bilstein - yara-signator at cocacoding dot com
Detects win_zupdax - 9 days ago

Dynamic Analysis Sandbox Detections

The sandbox DAS-Security Orcas flags this file as: MALWARE

Popular threat label trojan.redsip/sanwaicrypt Threat categories trojan Family labels redsip sanwaicrypt zupdax

Security vendors' analysis

AhnLab-V3 Malware/Gen.Generic.C1464467 Alibaba Backdoor:Win32/Zupdax.4fc05470

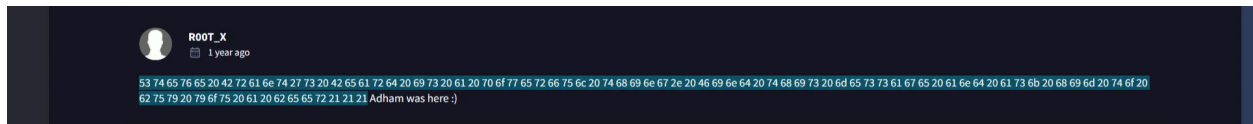
Answer:

9709473ab351387aab9e816eff3910b9f28a7a70202e250ed46dba8f820f34a8

#112

What special hex code is associated with the customized malware discussed in question 111?

from the community tab in VT



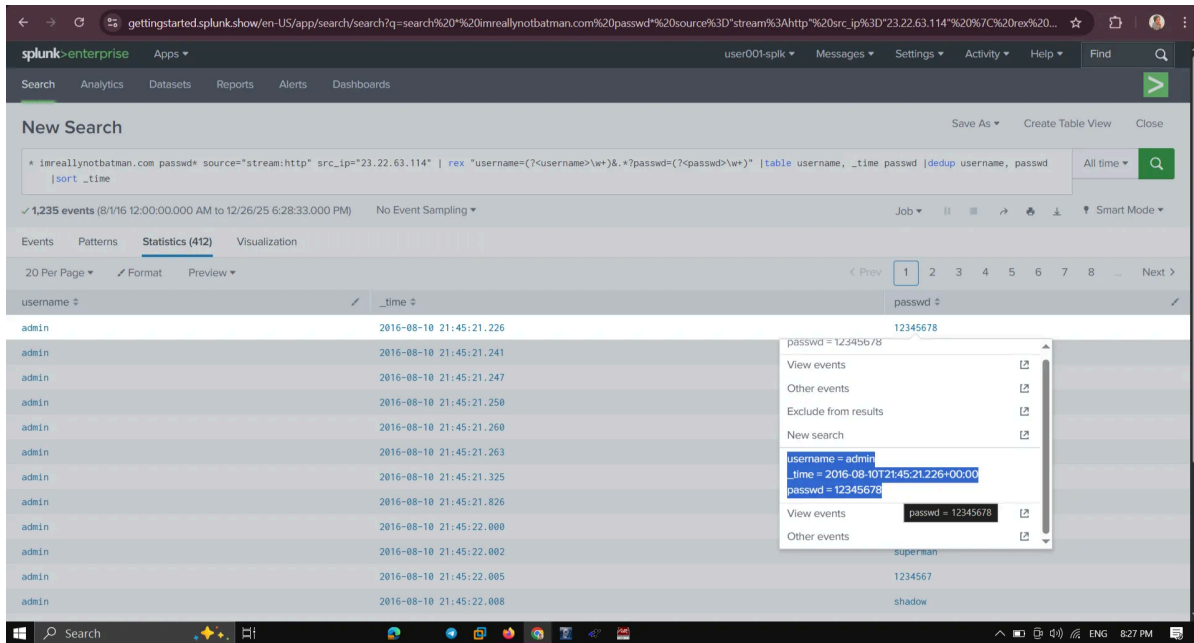
Ans:53 74 65 76 65 20 42 72 61 6e 74 27 73 20 42 65 61 72 64 20 69 73 20 61 20 70 6f 77 65 72 66 75 6c 20 74 68 69 6e 67 2e 20 46 69 6e 64 20 74 68 69 73 20 6d 65 73 73 61 67 65 20 61 6e 64 20 61 73 6b 20 68 69 6d 20 74 6f 20 62 75 79 20 79 6f 75 20 61 20 62 65 65 72 21 21 21

#114

What was the first brute force password used?

we will just modify #108 query

```
* imreallynotbatman.com passwd* source="stream:http" src_ip="23.22.63.114" | rex "username=(?<username>\w+)&.*?passwd=(?<passwd>\w+)" | table username, _time passwd | dedup username, passwd | sort _time
```



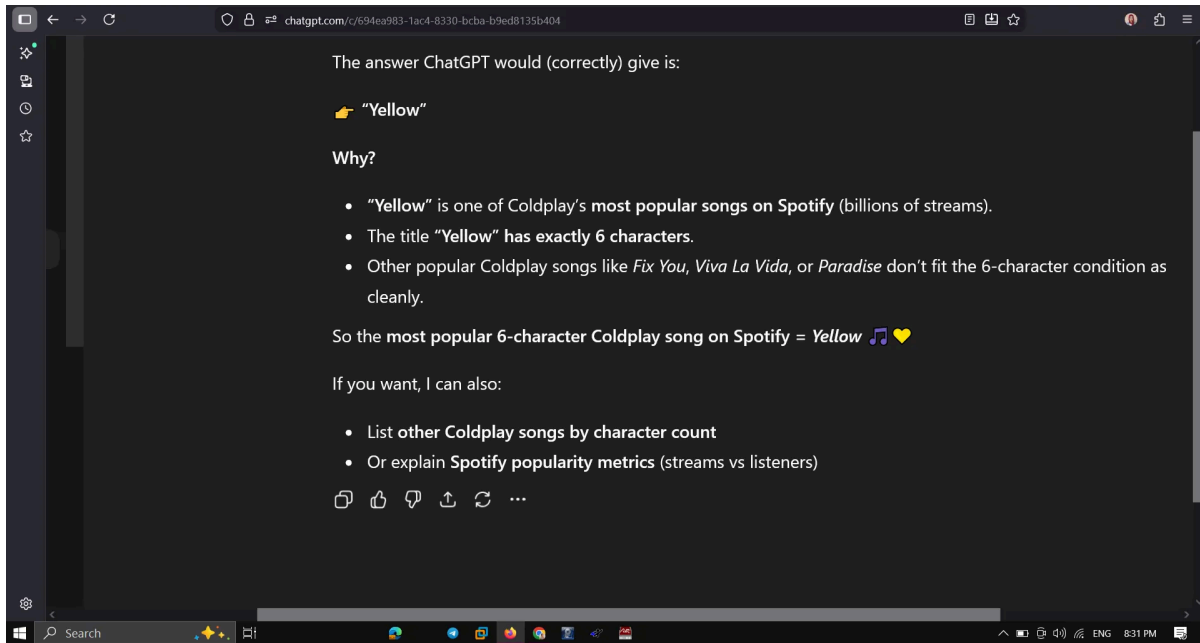
Answer: 12345678

#115

One

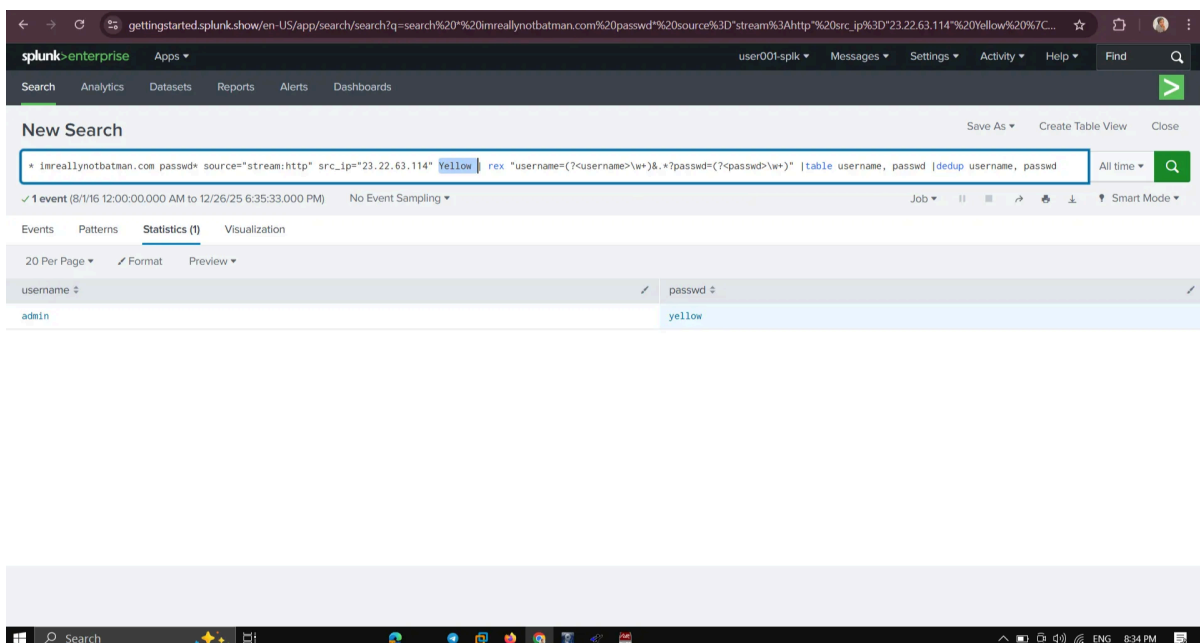
of the passwords in the brute force attack is James Brodsky's favorite Coldplay song. We are looking for a six character word on this one. Which is it?

i asked chatgpt the most popular 6 character Coldplay song



i just added Yellow in the Query to make sure

```
* imreallynotbatman.com passwd* source="stream:http" src_ip="23.22.63.114" Yellow | rex "username=(?<username>\w+)&.*?passwd=(?<passwd>\w+)" | table username, passwd | dedup username, passwd
```

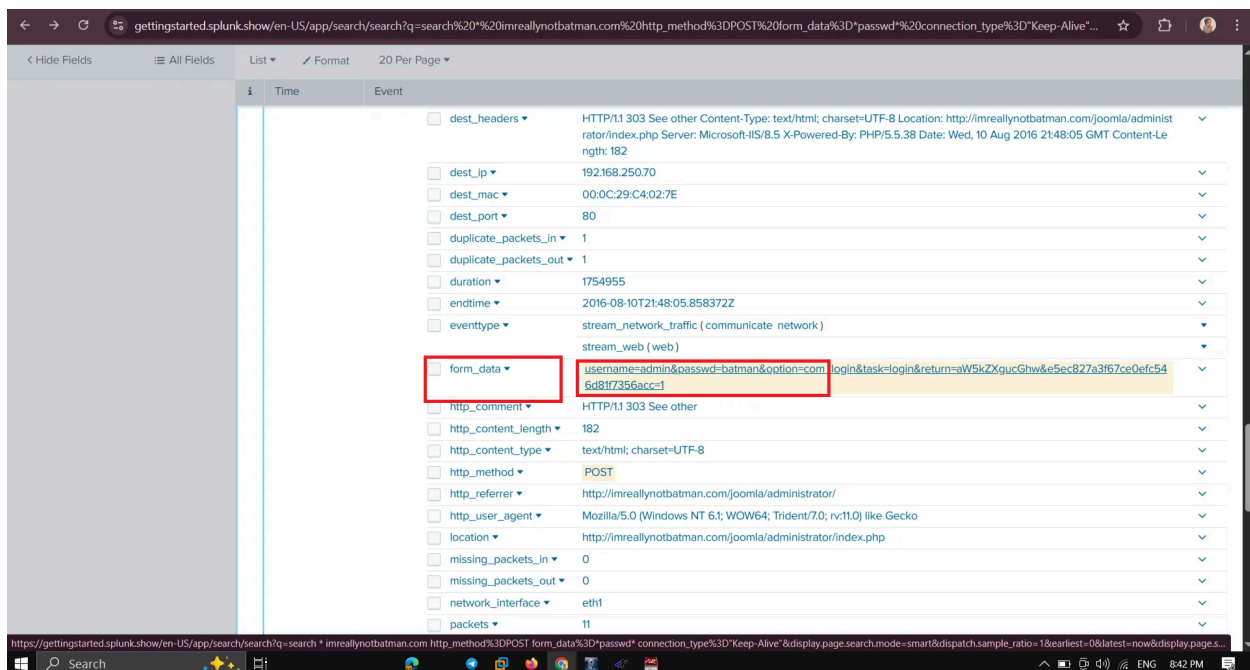


Ans:Yellow

#116

What was the correct password for admin access to the content management system running "imreallynotbatman.com"?

```
* imreallynotbatman.com http_method=POST form_data=*passwd* connection_type="Keep-Alive"
```



Ans:batman

#117

What was the average password length used in the password brute forcing attempt?

i asked deepsek to help me in this query

```
* imreallynotbatman.com passwd* source="stream:http" src_ip="23.22.63.114"
| rex "username=(?<username>\w+)&.*?passwd=(?<passwd>\w+)"
```



```
eval passwd_length = len(passwd)
stats avg(passwd_length) AS avg_password_length
```

The screenshot shows the Splunk Enterprise web interface. The search bar contains the following query:

```
* imreallynotbatman.com passwd* source='stream:http' src_ip='23.22.63.114'
| rex 'username=(?<username>\w+)&.*?passwd=(?<passwd>\w+)'
| eval passwd_length = len(passwd)
| stats avg(passwd_length) AS avg_password_length
```

The search results show 1,235 events. The 'Statistics (1)' tab is selected, displaying the following table:

avg_password_length
6.174757281553398

Ans:6

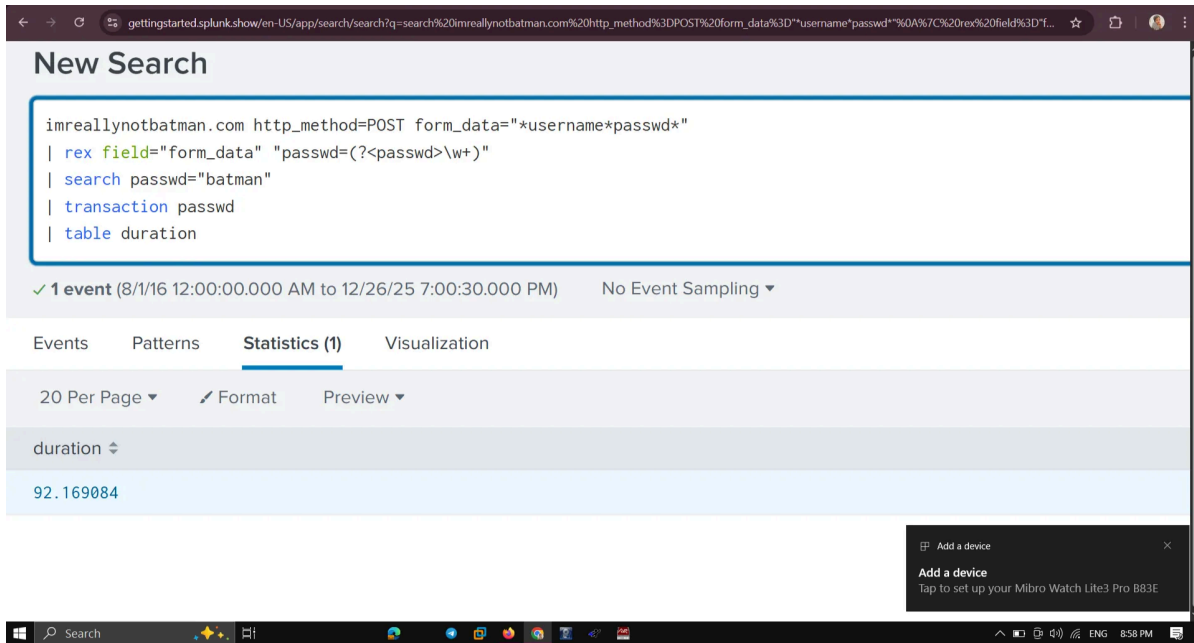
#118

How

many seconds elapsed between the time the brute force password scan identified the correct password and the compromised login?

I asked deepseek to give me query that query for elapses time

```
imreallynotbatman.com http_method=POST form_data="*username*passwd
*"
| rex field="form_data" "passwd=(?<passwd>\w+)"
| search passwd="batman"
| transaction passwd
| table duration
```



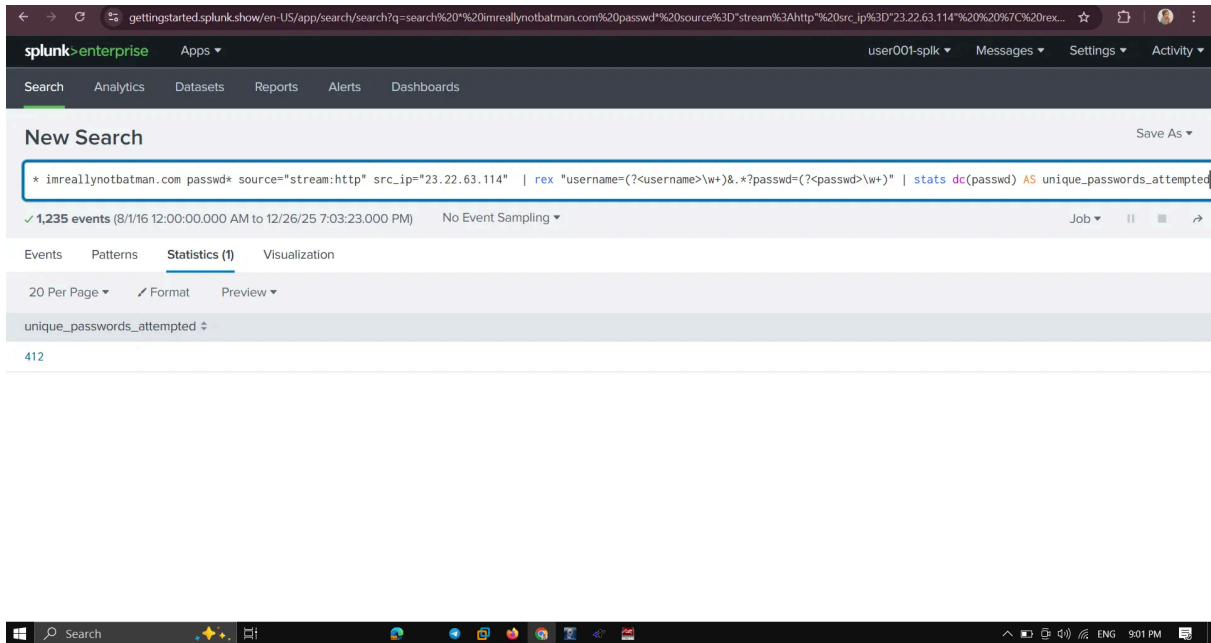
Ans:92.17

#119

How many unique passwords were attempted in the brute force attempt?

i also asked deepseek to create query to identify the unique passwords attempted by the two questions above.

```
* imreallynotbatman.com passwd* source="stream:http" src_ip="23.22.63.114" | rex "username=(?<username>\w+)&.*?passwd=(?<passwd>\w+)" | stats dc(passwd) AS unique_passwords_attempted
```



Ans:412

Summary of Indicators of Compromise (IOCs)

- **Threat Actor:** Po1s0n1vy APT group
- **Initial Access:** Spear-phishing with malicious attachment (custom malware)
- **Malicious IPs:**
 - Internal scanning source: 192.168.250.70
 - External scanning IP: 40.80.148.42
- **Malware Hash (MD5):** AAE3F5A29935E6ABCC2C2754D12A9AF0
- **Defacement Artifact:** poison ivy is coming for you batman.jpeg
- **Affected Website:** www.imreallynotbatman.com
- **Attack Outcome:** Successful website compromise and defacement

MITRE ATT&CK lifecycle observed:

21